

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

TAREA 2

MODELO DE AMENAZAS COMPLETO – OWASP THREAT DRAGON

Autor (es):
Hurtarte Revolorio, Jeffrey Obed – jhurtarter2@miumg.edu.gt

Profesor
Gallo Orozco, Osberto Saul

Curso
Seguridad en Aplicaciones – IV Trimestre - 2026

Guatemala, 2026

Tabla de contenido

Introducción 3
Objetivo general 4
Objetivos específicos 4
Alcance 4
Metodología 5
Levantamiento de arquitectura 6
Análisis STRIDE 12
Priorización de riesgos 18
Catálogo de casos de abuso 20
Conclusiones 30
Referencias 31

Introducción

El modelado de amenazas es un enfoque sistemático que facilita la identificación, comunicación y comprensión de amenazas y sus mitigaciones en relación con los activos a proteger (Threat Modeling Manifesto Working Group, 2020). Shostack (2014) lo clasifica en cuatro interrogantes: en qué se está laborando, qué podría ir mal, qué acciones se tomarán y si el análisis fue adecuado. En el ciclo de vida del desarrollo seguro, el Marco de Desarrollo Seguro de Software del Instituto Nacional de Estándares y Tecnología (NIST, 2022) incorpora el modelado de riesgos, como el modelado de amenazas, para analizar el riesgo de seguridad del software desde la fase de diseño (práctica PW.1.1). De manera similar, el OWASP Top 10:2021 menciona el modelado de amenazas como una respuesta al riesgo de un diseño inseguro (OWASP Foundation, 2021a).

Este informe registra el modelo de amenazas de la Plataforma de Banca Digital de un banco imaginario, "Banco Aurora", creado con OWASP Threat Dragon (OWASP Foundation) y la metodología STRIDE (Hernan, 2006).

Objetivo general

Diseñar y documentar un modelo de amenazas integral de la Plataforma de Banca Digital que identifique amenazas, evalúe riesgos, priorice la remediación y defina controles tempranos dentro del SSDLC.

Objetivos específicos

- Levantar la arquitectura, los activos críticos y los flujos de información de la plataforma.
- Construir los DFD de nivel 0, 1 y 2 con sus límites de confianza.
- Identificar amenazas con STRIDE sobre cada elemento del DFD.
- Priorizar riesgos por impacto y probabilidad.
- Documentar casos de abuso para amenazas críticas y altas.
- Mapear controles de seguridad y definir un plan y roadmap de remediación.

Alcance

Incluye canales web y móvil, API Gateway, servicios de autenticación, cuentas y transacciones, middleware de integración, core bancario, bases de datos, infraestructura asociada, flujos internos y externos, y dependencias de terceros (proveedor OTP/SMS, proveedor KYC y red ACH). Excluye la infraestructura física de los centros de datos y las redes de los clientes.

Metodología

- Levantamiento de arquitectura y activos.
- Modelado con DFD (niveles 0 a 2) en Threat Dragon.
- Identificación de amenazas con STRIDE: generación automática por el motor de reglas más análisis manual.
- Validación técnica con Arquitectura y Desarrollo.
- Valoración de riesgo con escala cualitativa de impacto y probabilidad, en línea con el enfoque de evaluación de riesgos del NIST (2012).
- Definición de casos de abuso, controles, plan de remediación y roadmap.

Levantamiento de arquitectura

Descripción de alto nivel (para el campo de Threat Dragon): Plataforma de banca digital que permite a clientes consultar saldos, realizar transferencias internas e interbancarias y pagar servicios mediante una aplicación web y una móvil. Los canales se conectan por un API Gateway a servicios de autenticación, cuentas y transacciones; un middleware de mensajería integra el core bancario y la red ACH. Se apoya en proveedores externos de OTP/SMS y verificación de identidad (KYC).

Tabla 1

Inventario de componentes

ID	Componente	Tipo	Zona	Interfaces / dependencias
CMP-01	App web (SPA)	Aplicación	Cliente/Internet	HTTPS → API Gateway
CMP-02	App Móvil (IOS/Android)	Aplicación	Cliente/Internet	HTTPS → API Gateway, SDK de terceros
CMP-03	WAF / CDN	Infraestructura	DMZ	Internet → Gateway
CMP-04	API Gateway	API	DMZ	OAuth 2.0/OIDC, rate limiting
CMP-05	Servicio de Autenticación (IdP)	Servicio	Aplicaciones	BD de identidades, caché de sesiones, proveedor OTP

CMP-06	Servicio de Cuentas y Transacciones	Servicio	Aplicaciones	BD transaccional, middleware, antifraude
CMP-07	Middleware de integración (MQ/ESB)	Integración	Aplicaciones	Core bancario, red ACH
CMP-08	Core bancario (host)	Sistema central	Core	Mensajería desde middleware
CMP-09	Servicio de Notificaciones	Servicio	Aplicaciones	Proveedor OTP/SMS
CMP-10	Backoffice / Administración	Aplicación interna	Corporativa	VPN + MFA, BD
CMP-11	Monitoreo y logging (SIEM)	Infraestructura	Operaciones	Recolecta eventos de todos los servicios
CMP-12	BD de identidades	Base de datos	Datos	Autenticación
CMP-13	BD transaccional	Base de datos	Datos	Cuentas y transacciones
CMP-14	Caché de sesiones	Almacén	Datos	Autenticación
CMP-15	Bóveda de secretos / HSM	Infraestructura	Datos	Servicios y middleware
CMP-16	Proveedor OTP/SMS	Tercero	Externa	API del proveedor
CMP-17	Proveedor KYC/biometría	Tercero	Externa	API del proveedor
CMP-18	Red ACH / switch interbancario	Tercero	Externa	Mensajería interbancaria
CMP-19	Almacén de logs	Almacén	Datos	Guarda eventos de todos los servicios

Nota. Elaboración propia.

Tabla 2

Inventario de activos de información

ID	Activo	Clasificación	C	I	D	Ubicación
A-01	Credenciales y factores de autenticación	Restringido	Alta	Alta	Alta	C-12, C-14
A-02	Datos personales de clientes (PII)	Confidencial	Alta	Media	Media	C-13, C-17
A-03	Saldos y movimientos	Confidencial	Alta	Alta	Alta	C-13, C-08
A-04	Órdenes de transferencia/pago	Crítico	Media	Alta	Alta	C-06, C-07
A-05	Tokens de sesión y acceso	Restringido	Alta	Alta	Media	C-14, C-04
A-06	Secretos, llaves y certificados	Restringido	Alta	Alta	Alta	C-15
A-07	Logs de auditoría	Confidencial	Media	Alta	Alta	C-11
A-08	Documentos de identidad (KYC)	Confidencial	Alta	Media	Baja	C-17
A-09	Código fuente y dependencias	Interno	Media	Alta	Media	Repositorio/ CI

Nota. Elaboración propia.

Tabla 3

Flujos de información y criticidad

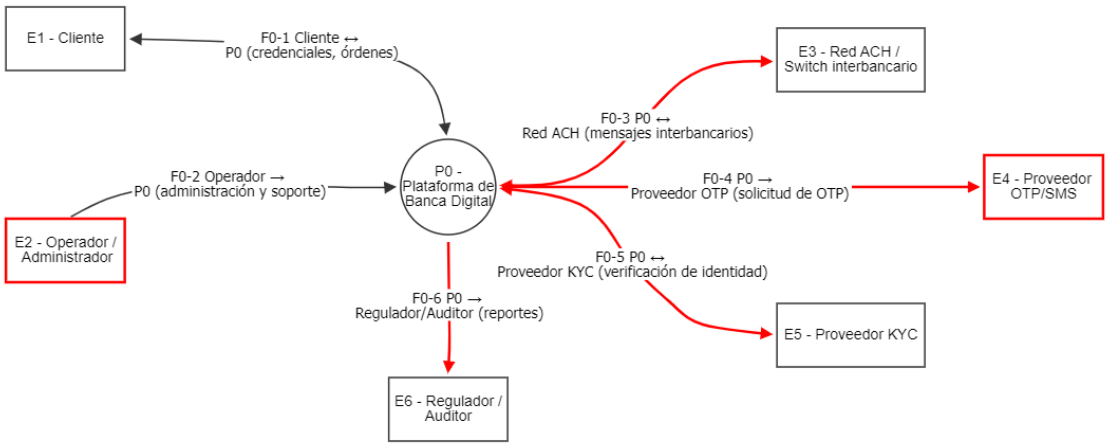
ID	Origen → Destino	Datos	Protocolo	Cruza	Criticidad
F1	E1 ↔ P1	Credenciales, órdenes	Interfaz de usuario	—	Crítica
F2	P1 ↔ P2	Solicitudes API, tokens	HTTPS / TLS 1.3	TB1	Crítica
F3	P2 → P3	Validación de token	mTLS	TB2	Crítica
F4	P3 ↔ D1	Hashes, perfiles	TLS / SQL	TB3	Crítica
F5	P3 ↔ D3	Sesiones	TLS	TB3	Alta
F6	P2 → P4	Consultas, órdenes	mTLS	TB2	Crítica
F7	P4 ↔ D2	Saldos, movimientos	TLS / SQL	TB3	Crítica
F8	P4 → P5	Mensajes de transacción	MQ sobre TLS	—	Crítica
F9	P5 ↔ P6	Posteo	Protocolo del host	TB4	Crítica
F10	P5 ↔ E3	Mensajes interbancarios	Canal dedicado	TB5	Crítica
F11	P7 → E4	Número y mensaje OTP	HTTPS	TB5	Alta
F12	P3 ↔ E5	Datos de identidad	HTTPS	TB5	Alta
F13	E2 → P8	Acceso administrativo	VPN + HTTPS	TB4	Alta
F14a	P2 → P9	Eventos	TLS	TB2	Media
F14b-d	P3, P4, P5 → P9	Eventos	TLS	—	Media
F14e	P8 → P9	Eventos	TLS	TB4	Media

F14f	P9 → D4	Eventos	TLS	TB3	Media
F15a-c	P3, P4, P5 → D5	Solicitud de secretos	mTLS	TB3	Alta
F16	P9 → E6	Reportes	Exportación segura	TB5	Media
F17	P8 → P4	Operaciones de soporte	HTTPS interno	TB4	Alta
F18	P3 → P7	Solicitud de OTP	TLS interno	—	Alta
F19	P4 → P7	Avisos de operación	TLS interno	—	Media

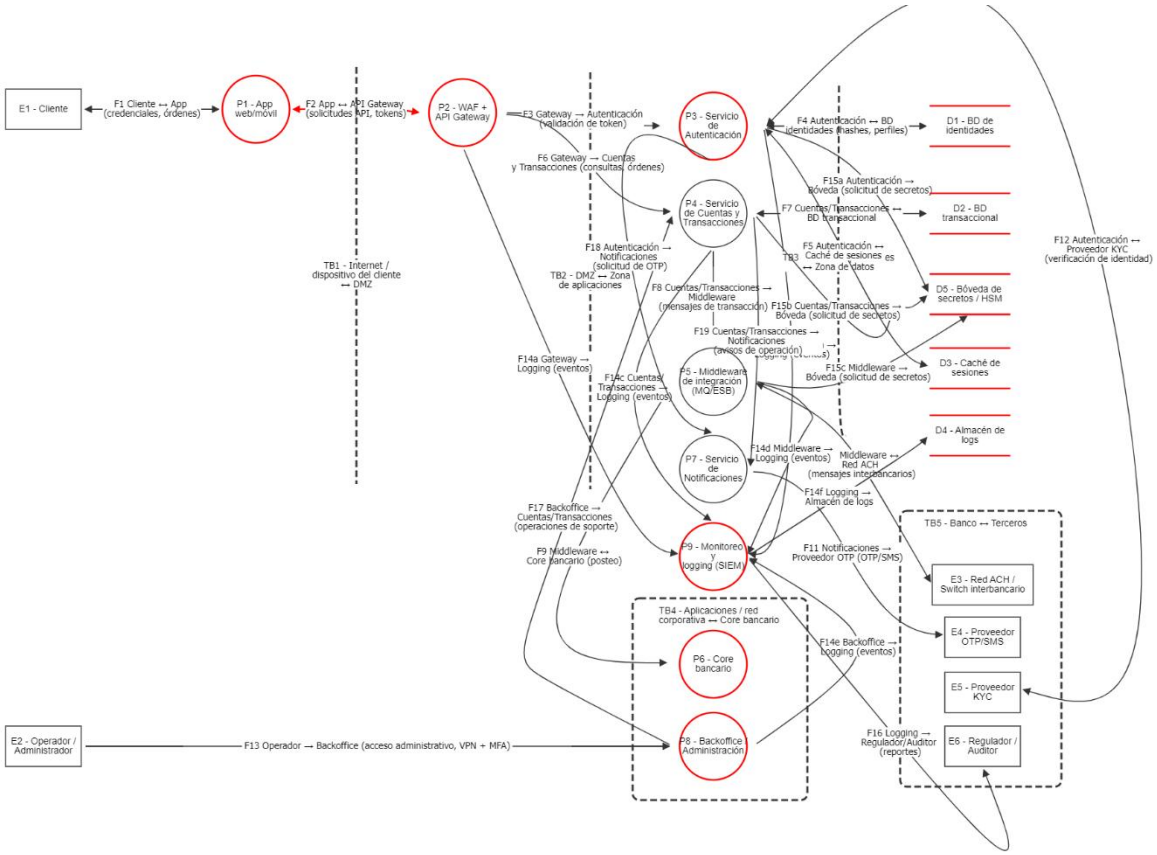
Nota. Elaboración propia.

Esquemas de flujo de datos

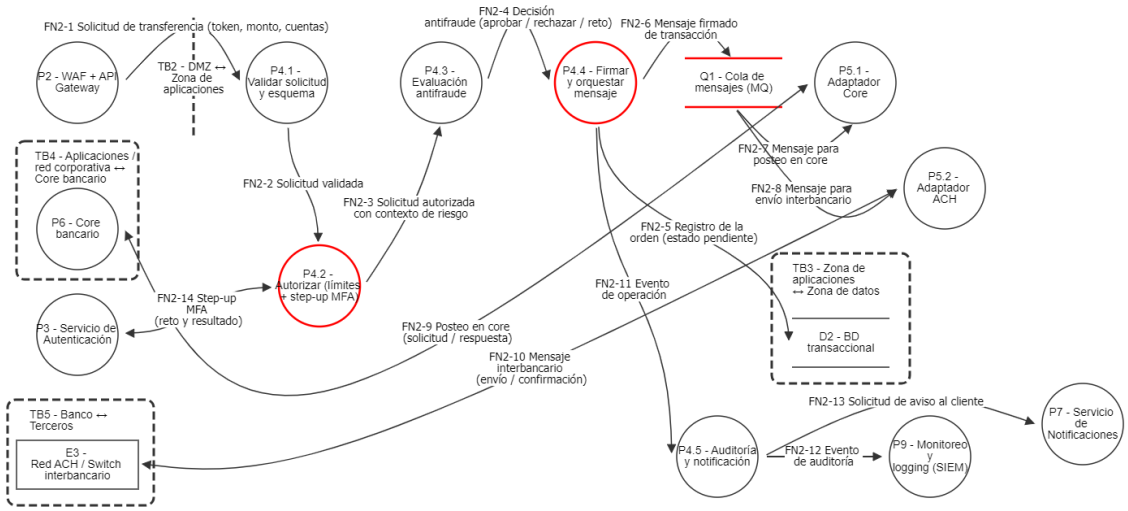
- DFD Nivel 0 (Contexto). La Plataforma de Banca Digital (P0) se relaciona con seis organizaciones externas: cliente (E1), operador (E2), red ACH (E3), proveedor OTP/SMS (E4), proveedor KYC (E5) y regulador/auditor (E6), a través de seis flujos (F0-1 a F0-6). Se documentaron seis amenazas vinculadas a las entidades externas y sus integraciones: T-08, T-12, T-20, T-21, T-24 y T-25.



- DFD Nivel 1 (Procesos). Incluye 20 componentes (6 entidades externas, 9 procesos y 5 repositorios de datos), 26 flujos y cinco límites de confianza (TB1 a TB5). Se documentaron 15 amenazas: T-01, T-02, T-05, T-06, T-09, T-10, T-11, T-13, T-14, T-15, T-16, T-18, T-19, T-22 y T-23. Los procesos P4 y P5 se dividen en el Nivel 2 y sus amenazas se anotan allí.



- DFD Nivel 2 (Transacciones). Descompone P4 (cuentas y transacciones) y la sección de P5 que trata las transferencias: 15 componentes (7 procesos propios, 2 almacenes y 6 elementos de contexto), 14 flujos y cuatro límites. Se registraron cuatro amenazas: T-03 y T-04 (P4.2), T-17 (P4.4) y T-07 (Q1).



Análisis STRIDE

Tabla 4

Matriz STRIDE consolidada (ID's de amenaza por categoría)

Diagrama	Elemento	S	T	R	I	D	E
N0	E2 Operador	T-20					
N0	E3 Red ACH		T-21				
N0	E4 Proveedor OTP	T-08				T-25	
N0	E5 Proveedor KYC				T-12		
N0	E6 Regulador				T-24		
N1	F2 App ↔ Gateway		T-02				
N1	P1 App web/móvil		T-15		T-23		
N1	P2 WAF + Gateway				T-19	T-10	

N1	P3 Autenticación	T-01					
N1	P6 Core bancario					T-16	
N1	P8 Backoffice						T-06
N1	P9 Monitoreo/ SIEM			T-09			
N1	D1 BD identidades				T-18		
N1	D2 BD transaccional				T-05		
N1	D3 Caché de sesiones	T-11				T-22	
N1	D4 Almacén de logs				T-13		
N1	D5 Bóveda de secretos				T-14		
N2	P4.2 Autorizar		T-03				T-04
N2	P4.4 Firmar y orquestar			T-17			
N2	Q1 Cola MQ		T-07				

Nota. Elaboración propia.

Tabla 5

Inventario de amenazas, valoración y riesgo

ID	Diagrama/ Elemento	STRIDE	Amenaza	Imp.	Prob.	Pts.	Riesgo
T-01	N1 / P3	S	Toma de cuenta por credential stuffing, phishing en tiempo real o MFA débil	Crítico	Muy Alta	16	**Crítico**
T-02	N1 / F2	T	Manipulación de monto/destino en tránsito (MITM, app instrumentada)	Crítico	Alta	12	**Crítico**
T-03	N2 / P4.2	T	BOLA/IDOR: operar sobre cuentas ajenas modificando identificadores	Crítico	Alta	12	**Crítico**
T-04	N2 / P4.2	E	Evasión de step-up y límites (BFLA, endpoints legacy)	Alto	Alta	9	**Crítico**
T-05	N1 / D2	I	Inyección SQL y exfiltración masiva	Crítico	Media	8	Alto

T-06	N1 / P8	E	Abuso de privilegios por insider, sin doble aprobación	Crítico	Media	8	Alto
T-07	N2 / Q1	T	Manipulación o repetición (replay) de mensajes en la cola	Crítico	Media	8	Alto
T-08	N0 / E4	S	Intercepción de OTP por SIM swap o malware	Alto	Alta	9	**Crítico**
T-09	N1 / P9	R	Logs sin integridad: negación de operaciones	Alto	Media	6	Alto
T-10	N1 / P2	D	DDoS o scraping por ausência de rate limiting	Alto	Media	6	Alto
T-11	N1 / D3	S	Secuestro de sesión o token sin rotación/revocación	Alto	Media	6	Alto
T-12	N0 / E5	I	Brecha en proveedor KYC que expone documentos de identidad	Crítico	Media	8	Alto

T-13	N1 / D4	I	Datos sensibles en logs en texto claro	Medio	Alta	6	Alto
T-14	N1 / D5	I	Secretos expuestos en repositorios, variables o imágenes	Crítico	Media	8	Alto
T-15	N1 / P1	T	App reempaquetada o SDK de terceros comprometido	Alto	Media	6	Alto
T-16	N1 / P6	D	Saturación del core por picos desde canales digitales	Crítico	Baja	4	Medio
T-17	N2 / P4.4	R	Cliente niega una transferencia (sin firma de transacción)	Medio	Media	4	Medio
T-18	N1 / D1	I	Hashes de contraseña expuestos con algoritmo débil	Alto	Baja	3	Medio
T-19	N1 / P2	I	Errores verbosos y cabeceras que	Bajo	Alta	3	Medio

			revelan tecnología				
T-20	N0 / E2	S	Suplantación de operador por credenciales compartidas	Medio	Media	4	Medio
T-21	N0 / E3	T	Alteración o suplantación de mensajes con la red ACH	Crítico	Baja	4	Medio
T-22	N1 / D3	D	Agotamiento de caché y caída de sesiones	Medio	Baja	2	Bajo
T-23	N1 / P1	I	Datos sensibles en almacenamiento local/capturas de pantalla	Medio	Media	4	Medio
T-24	N0 / E6	I	Reportes de auditoría con PII sin controles	Bajo	Media	2	Bajo

T-25	N0 / E4	D	Saturación del proveedor SMS: OTP no entregados	Bajo	Baja	1	Bajo

Nota. Elaboración propia.

Priorización de riesgos

Parametrización (consistente con la tabla de referencia del enunciado: Alto×Alto = Crítico, Alto×Medio = Alto, Medio×Medio = Medio, Bajo×Bajo = Bajo)

Impacto	Valor	Probabilidad	Valor
Crítico	4	Muy Alta	4
Alto	3	Alta	3
Medio	2	Media	2
Bajo	1	Baja	1

Puntaje = Impacto × Probabilidad. Nivel: 1-2 Bajo; 3-5 Medio; 6-8 Alto; 9-16 Crítico

Tabla 6

Matriz de riesgos

Probabilidad	Baja (1)	Media (2)	Alta (3)	Muy Alta (4)
Impacto				
Crítico (4)	4 Medio (T-16, T-21)	8 Alto (T-05, 06, 07, 12, 14)	12 Crítico (T-02, T-03)	16 Crítico (T-01)
Alto (3)	3 Medio (T-18)	6 Alto (T-09, 10, 11, 15)	9 Crítico (T-04, T-08)	12 Crítico

Medio (2)	2 Bajo (T-22)	4 Medio (T-17, 20, 23)	6 Alto (T-13)	8 Alto
Bajo (1)	1 Bajo (T-25)	2 Bajo (T-24)	3 Medio (T-19)	4 Medio

Distribución: 5 Críticos, 10 Altos, 7 Medios, 3 Bajos (25 amenazas).

Tabla 7

Top 10 de hallazgos prioritarios

No.	ID	Hallazgo	Pts	Riesgo
1	T-01	Toma de cuenta por autenticación débil	16	Crítico
2	T-02	Manipulación de transacciones en tránsito	12	Crítico
3	T-03	BOLA/IDOR en transferencias	12	Crítico
4	T-04	Evasión de step-up y límites	9	Crítico
5	T-08	Intercepción de OTP por SIM swap	9	Crítico
6	T-05	Inyección SQL / exfiltración	8	Alto
7	T-06	Abuso de privilegios internos	8	Alto
8	T-07	Manipulación/replay en cola de mensajes	8	Alto

9	T-12	Brecha en proveedor KYC	8	Alto
10	T-14	Exposición de secretos	8	Alto

Resumen: cinco de las diez amenazas principales se concentran en identidad, autorización de transacciones y segundo factor, de modo que el mayor retorno de remediación está en fortalecer esos tres frentes antes que en la infraestructura perimetral.

Catálogo de casos de abuso

AC-01: Toma de cuenta (T-01) | Actor: atacante externo | STRIDE: Spoofing | Riesgo: Crítico:

- Objetivo: acceder sin autorización a cuentas y mover fondos.
- Vector: endpoint de login y APIs de autenticación (web y móvil).
- Precondiciones: credenciales reutilizadas por el cliente; MFA ausente o basado en SMS; rate limiting insuficiente por cuenta/dispositivo.
- Método: credential stuffing automatizado; phishing con proxy inverso que captura la sesión y el OTP.
- Impacto: fraude financiero, pérdida de confianza, sanción regulatoria.
- Preventivo: MFA resistente a phishing (FIDO2/passkeys), vinculación de dispositivo, rate limiting adaptativo, verificación de credenciales filtradas.
- Detectivo: alertas por ráfagas de fallos, viaje imposible, dispositivo nuevo + beneficiario nuevo.

- Correctivo: revocar sesiones, restablecimiento con verificación fuerte, reversión de operaciones, notificación al cliente.

AC-02: Manipulación de transacción en tránsito (T-02) | Actor: atacante externo o malware | STRIDE: Tampering | Riesgo: Crítico:

- Objetivo: alterar monto o cuenta destino.
- Vector: tráfico App → API.
- Precondiciones: dispositivo comprometido o red hostil; app sin pinning ni firma de petición.
- Método: proxy interceptor con certificado instalado, instrumentación en tiempo de ejecución, edición de parámetros.
- Impacto: transferencias fraudulentas, pérdida económica.
- Preventivo: TLS 1.3, certificate pinning, firma de transacción verificada en servidor, validaciones de negocio server-side, attestation del dispositivo.
- Detectivo: verificación de integridad del payload, alertas antifraude por desvío de patrón.
- Correctivo: congelar fondos, revocar credenciales del dispositivo, análisis forense.

AC-03: Acceso a objetos ajenos, BOLA (T-03) | Actor: usuario autenticado malicioso | STRIDE: Tampering | Riesgo: Crítico:

- Objetivo: consultar u operar cuentas de terceros.
- Vector: API REST (por ejemplo /accounts/{id}/transfers).

- Precondiciones: identificadores predecibles; autorización basada solo en “estar autenticado”.
- Método: enumeración y sustitución del identificador de cuenta origen.
- Impacto: exposición masiva de datos y fraude.
- Preventivo: verificación de propiedad del objeto en servidor, identificadores no secuenciales (UUID), pruebas automatizadas de autorización en CI.
- Detectivo: alertas por acceso a múltiples cuentas desde una sesión y picos de 403/404.
- Correctivo: parche urgente, revisión retroactiva de logs, notificación a afectados.

AC-04: Evasión de step-up y límites (T-04) | Actor: usuario malicioso o malware | STRIDE: Elevation of Privilege | Riesgo: Crítico:

- Objetivo: transferir sobre los límites sin segundo factor.
- Vector: versiones antiguas de la API o endpoints alternos.
- Precondiciones: endpoints legacy sin step-up; límites validados solo en el cliente.
- Método: invocar directamente la API antigua o alterar indicadores de riesgo.
- Impacto: fraude de alto monto.
- Preventivo: punto central de decisión de autorización, step-up por riesgo, retiro de versiones obsoletas, inventario de APIs.
- Detectivo: monitoreo de uso de endpoints deprecados y de montos atípicos.
- Correctivo: bloqueo del endpoint, reversión, recalibración de límites.

AC-05: Intercepción de OTP (T-08) | Actor: atacante con ingeniería social | STRIDE: Spoofing | Riesgo: Crítico:

- Objetivo: obtener el OTP para autorizar operaciones.
- Vector: canal SMS y proveedor OTP.
- Precondiciones: SMS como único segundo factor; controles débiles de cambio de SIM.
- Método: SIM swap, malware lector de SMS, phishing.
- Impacto: toma de cuenta y autorización fraudulenta.
- Preventivo: migrar a notificación push autenticada, TOTP o FIDO2 ligados al dispositivo; señales de cambio de SIM del operador; límites de reintentos.
- Detectivo: correlación cambio de SIM + login; OTP solicitados en ráfaga.
- Correctivo: invalidar el factor, reenrolamiento con verificación fuerte.

Tabla 8

Casos de abuso AC-06 a AC-15

AC	Amenaza	Objetivo	Vector y método	Precondiciones	Impacto
AC-06	T-05 SQLi	Exfiltrar datos de clientes	Parámetros de búsqueda de movimientos; inyección SQL	Consultas concatenadas; cuenta de BD con privilegios excesivos	Filtración de PII y saldos
AC-07	T-06 Insider	Alterar saldos o extraer datos	Consola de backoffice con roles amplios	Sin segregación de funciones ni doble aprobación	Fraude interno

AC-08	T-07 MQ	Alterar o duplicar transacciones	Inyección o replay de mensajes en la cola	Canal sin autenticación mutua ni firma	Pagos duplicados o alterados
AC-09	T-09 Repudio	Negar una operación	Logs modificables sin correlación de usuario	Logs sin integridad ni sincronía horaria	Imposibilidad de probar el fraude
AC-10	T-10 DoS	Interrumpir el canal	DDoS de capa 7 y scraping	Sin anti-DDoS ni rate limiting	Indisponibilidad, incumplimiento de SLA
AC-11	T-11 Sesión	Secuestrar sesión	Robo de token (XSS, malware) o fijación	Tokens largos sin rotación, almacenados en el navegador	Operaciones con identidad ajena
AC-12	T-12 KYC	Obtener documentos de identidad	Brecha en el proveedor	Envío de datos completos; sin minimización	Filtración de PII, riesgo regulatorio
AC-13	T-14 Secretos	Obtener credenciales de servicios	Secretos en repositorios, variables o imágenes	Sin bóveda ni escaneo de secretos	Compromiso lateral de sistemas
AC-14	T-13 Logs	Leer datos sensibles vía logs	Acceso a logs con PAN/tokens en claro	Sin enmascaramiento en origen	Exposición de datos sensibles
AC-15	T-15 App	Ejecutar código malicioso en dispositivos	App reempaquetada o SDK comprometido	Sin attestation ni revisión de dependencias	Robo de credenciales de clientes

Nota. Elaboración propia.

Tabla 9

Casos de abuso AC-06 a AC-15 (Controles)

AC	Preventivo	Detectivo	Correctivo
AC-06	Consultas parametrizadas, mínimo privilegio en BD, WAF	Monitoreo de actividad en BD, alertas de volumen de lectura	Parche, rotación de credenciales de BD, notificación del incidente
AC-07	PAM, segregación de funciones, doble aprobación	UEBA sobre acciones privilegiadas, recertificación de accesos	Revocar acceso, investigación forense
AC-08	mTLS, firma de mensajes, claves de idempotencia, ACL en colas	Conciliación automática, alertas de duplicados	Reversos y reconciliación
AC-09	Logs inmutables, NTP, ID de correlación, firma de transacción	Verificación periódica de integridad de logs	Reconstrucción forense, refuerzo del registro
AC-10	CDN/anti-DDoS, rate limiting, autoscaling, colas	Monitoreo de tráfico y latencia, alertas	Plan de respuesta DDoS, bloqueo upstream
AC-11	Tokens de vida corta con rotación, cookies HttpOnly/Secure/SameSite, CSP	Alertas por sesión en IP o dispositivos distintos	Revocación global de sesiones

AC-12	Minimización y tokenización, cláusulas contractuales, evaluación del proveedor	Monitoreo de proveedores, inteligencia de amenazas	Respuesta conjunta, notificación regulatoria
AC-13	Bóveda/HSM, rotación, escaneo de secretos pre-commit	Escaneo continuo, alertas de uso anómalo	Rotación y revocación inmediatas
AC-14	Enmascaramiento en origen, control de acceso a logs	DLP sobre logs	Depuración y rotación de datos expuestos
AC-15	Attestation, ofuscación, firma, SCA y SBOM	Detección de apps clonadas en tiendas	Retiro de apps, actualización forzada

Nota. Elaboración propia.

Tabla 10

Catálogo de controles

ID	Categoría	Control	Amenazas mitigadas
C-01	Aplicación	MFA resistente a phishing (FIDO2/passkeys) y vinculación de dispositivo	T-01, T-08, T-20
C-02	Aplicación	Gestión de sesiones: tokens cortos, rotación, revocación, cookies seguras	T-01, T-11
C-03	Aplicación	Validación de entradas, consultas parametrizadas, codificación de salida	T-05, T-19
C-04	Aplicación	Autorización por objeto y función, denegación por defecto	T-03, T-04, T-06
C-05	Aplicación	Firma de transacción y step-up por riesgo	T-02, T-04, T-17
C-06	Aplicación	TLS 1.3, pinning, attestation y ofuscación móvil	T-02, T-15, T-23

C-07	Aplicación	Cifrado en reposo, tokenización y gestión de llaves (KMS/HSM)	T-05, T-12, T-14, T-18
C-08	API	OAuth 2.0 / OIDC con PKCE y alcances mínimos	T-03, T-04, T-11
C-09	API	Rate limiting, anti-bot, WAF y anti-DDoS	T-01, T-10, T-16
C-10	API	Seguridad del API Gateway: validación de esquema OpenAPI, mTLS interno, inventario de versiones	T-02, T-04, T-19
C-11	Infraestructura	Segmentación y microsegmentación entre zonas (TB1-TB5)	T-05, T-07, T-16, T-21
C-12	Infraestructura	Hardening (CIS), parchado, SAST/DAST/SCA y SBOM	T-05, T-15, T-19
C-13	Infraestructura	Gestión de secretos con bóveda, rotación y escaneo	T-14

C-14	Infraestructura	PAM, segregación de funciones, doble aprobación	T-06, T-20
C-15	Infraestructura	Mensajería firmada, idempotencia y anti-replay	T-07, T-21
C-16	Monitoreo	Logging centralizado inmutable con enmascaramiento	T-09, T-13, T-24
C-17	Monitoreo	SIEM, UEBA y alertamiento (velocity, nuevo beneficiario, viaje imposible)	T-01, T-03, T-06, T-08
C-18	Monitoreo	Motor antifraude con puntaje de riesgo transaccional	T-01, T-02, T-03, T-08
C-19	Gobierno	Gestión de terceros: evaluación, contratos, plazos de notificación	T-12, T-15, T-25
C-20	Resiliencia	Colas, circuit breakers, autoscaling y DR	T-10, T-16, T-22, T-25

Nota. Elaboración propia.

Conclusiones

El modelado de la Plataforma de Banca Digital permite registrar 25 amenazas sobre 20 elementos de tres diagramas de flujo de datos, con una distribución de 5 riesgos críticos, 10 altos, 7 medios y 3 bajos. La concentración de riesgos críticos en autenticación, autorización de transacciones y segundo factor indica que las decisiones de diseño sobre identidad y control de acceso influyen más en la postura de seguridad que los controles perimetrales. Los cinco límites de confianza identificados mostraron que los puntos de mayor exposición son el borde con el cliente (TB1) y la relación con terceros (TB5), donde el banco tiene menor control.

La aplicación de los controles propuestos reduce los cinco riesgos críticos a niveles de riesgo residual medio o alto, con el phishing dirigido al usuario como el vector que más persiste. Se recomienda mantener el modelo en OWASP Threat Dragon como artefacto vivo del SSDLC, revisarlo ante cada cambio arquitectónico relevante e incorporar pruebas de autorización y de abuso en la integración continua, en línea con las prácticas de diseño seguro del NIST (2022).

Referencias

Hernan, S., Lambert, S., Ostwald, T., & Shostack, A. (2006, noviembre). Uncover security design flaws using the STRIDE approach. MSDN Magazine. Microsoft.

International Organization for Standardization & International Electrotechnical Commission. (2022). Information security, cybersecurity and privacy protection: Guidance on managing information security risks (ISO/IEC Standard No. 27005:2022).

National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30, Rev. 1). https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2022). Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities (NIST Special Publication 800-218). https://doi.org/10.6028/NIST.SP.800-218

OWASP Foundation. (s. f.-a). OWASP Threat Dragon. https://owasp.org/www-project-threat-dragon/

OWASP Foundation. (s. f.-b). Threat modeling cheat sheet. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html

OWASP Foundation. (2021a). OWASP Top 10:2021. https://owasp.org/Top10/

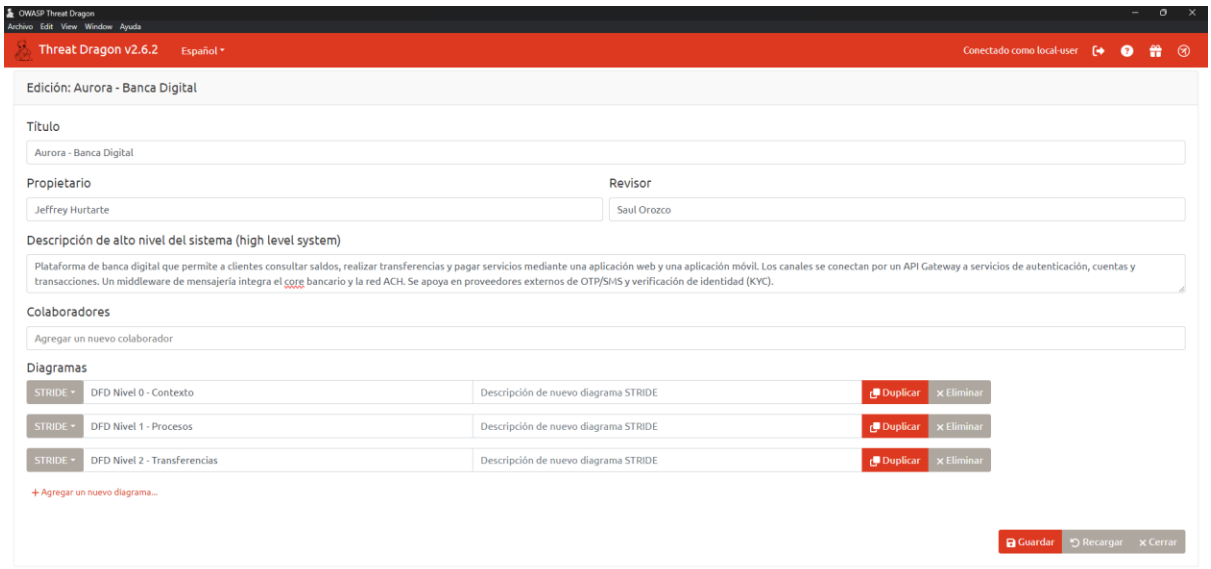
OWASP Foundation. (2021b). OWASP Application Security Verification Standard (Versión 4.0.3). https://owasp.org/www-project-application-security-verification-standard/

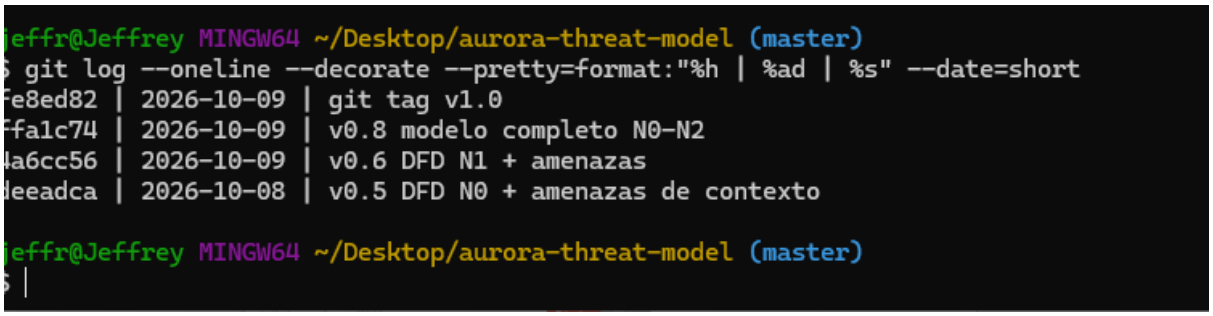
OWASP Foundation. (2023). OWASP API Security Top 10: 2023. https://owasp.org/API-Security/

Shostack, A. (2014). Threat modeling: Designing for security. John Wiley & Sons.

Threat Modeling Manifesto Working Group. (2020). Threat modeling manifesto. https://www.threatmodelingmanifesto.org/

Anexos





Repo Github:
https://github.com/JeffreyHurtarte/aurora-threat-model.git